

AI 자율침투 이후,
Heracles는 무엇을 더 지키는가

Heracles · pg_tde · MongoDB Queryable Encryption
보호 경계, 현재 한계, 그리고 검증할 차이

설계·코드 기반 / 비교 실험 전

침해 이후의 피해를, 구조와 시간으로 본다

어디까지 침해됐는가

파일 사본 · DB 계정 · DB 호스트 · 앱
같은 “해킹 성공”도 확보한 권한과
신뢰 영역이 다르면 결과가 달라진다.

무엇이 추가로 노출되는가

원문 · 검색어 · 복호 키 · 속성 추론
직접 읽기와 온라인 요청, 오프라인
재사용의 범위를 나누어 확인한다.

피해는 평문·키·권한의 배치와 탐지·회수까지 걸리는 시간이 함께 결정한다.

평가 범위: 초기 침투 성공률과 침해 이후 데이터 보호는 별도로 측정

먼저 공격자가 장악한 영역을 고정한다

앱 영역

사용자 권한 · 드라이버
정상 입력과 최종 평문

→

DB 영역

DB 엔진 · 플러그인 · 데몬
데이터 파일과 검색 인덱스

→

키 서비스 영역

키 보관 또는 원격 암호 연산
독립 인증·집행 경계

시나리오별 침해 영역만 표시

ARTEX / 모델 제어 · 독립 검증기
대상 환경의 권한·정답 데이터와 분리

모든 표면을 “시도”했다는 것과 모든 신뢰 영역을 “장악”했다는 것은 다르다.

별도 신뢰 경계가 전제. 한 호스트의 컨테이너만으로 호스트 root 격리를 주장하지 않음

같은 검색을 해도, 평문과 키의 경로는 다르다

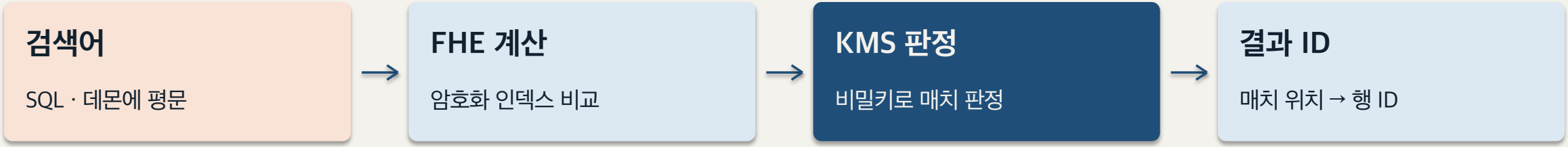
구분	pg_tde + 외부 키 관리	MongoDB QE + KMS	Heracles Mode 1
보호 값 저장	암호화된 DB 파일	암호화된 보호 필드	AES 원문 + FHE 인덱스
질의 값 / 계산	DB가 평문 값으로 비교	클라이언트가 보호 질의 값을 암호화	현재 검색어는 평문 인덱스 위에서 동형 연산
복호 키 사용	DB 프로세스	앱의 암호화 클라이언트	외부 KMS 워커
원문 반환	DB → 앱, 평문	DB → 앱, 암호문 앱에서 복호	KMS → 데몬 → DB → 앱 현재 평문 반환 경로

“키가 외부 KMS에 있다”만으로 키 사용 위치와 평문 노출이 같아지지 않는다.

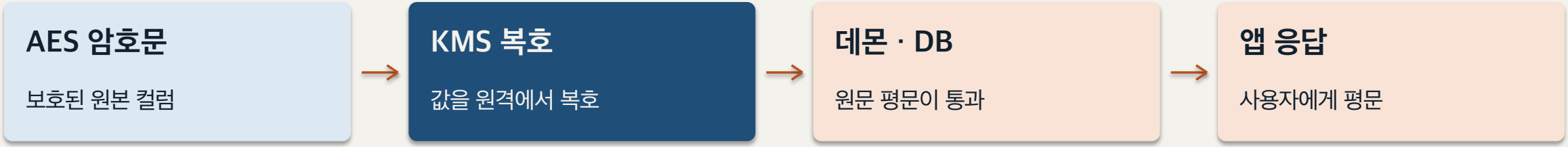
근거: pg_tde Architecture · MongoDB QE Features · Heracles overview / Mode 1 §2-4

검색 경로와 원문 복호 경로를 함께 봐야 한다

검색 전용 — 원본 AES 컬럼을 복호하지 않고 일치 ID 계산



원문 조회 — 현재 같은 DB 호스트에서 요청할 수 있는 별도 경로



복호 키가 없어도 복호 능력은 남을 수 있다. 두 경로 모두 공격·관측 범위에 포함한다.

근거: Mode 1 §3·4a · dataplane/server.go handleAesDecrypt · kms.go DecryptColumn

검색 중 평문을 줄여도, 다른 시점에 노출될 수 있다

단계	현재 Mode 1에서 확인할 경로	실험에서 나누어 볼 것
적재 · 쓰기	encrypt / 일반 append는 원문 통과 cc-append의 AES 준비 경로는 별도 확인	초기 적재와 서비스 중 쓰기
검색만 수행	검색어는 평문, 원본 AES 복호 불필요	질의·ID·결과 수·속성 추론
원문 조회	KMS가 반환한 평문이 데몬·DB 통과	배치·캐시·로그·메모리
재색인 · 복구	일부 경로는 원문 복호 후 다시 색인	정비 중 평문과 남은 흔적

실제 서비스 부하는 검색·조회·쓰기·정비를 구분해 재현한다.

근거: Heracles overview §1.2 · architecture §3-4 / GAP-1

FHE, 원격 키 사용, 정책의 기여를 따로 검증한다

기술

FHE 검색 계산

원본을 복호하지 않고
암호화 인덱스로 검색

단독으로 질의·메타데이터·
허용 결과의 추론을 없애지는 않음

구조

원격 키 사용

복호 키를 계산 호스트에
배포하지 않는 구성

호출 권한이 남으면
온라인 복호는 가능

통제

요청 통제 정책

주체·대상·수량별로
요청을 기록하고 제한

침해된 호스트 밖에서
실제로 집행되는지 검증

전체 피해 감소가 보이면, 어느 요소가 기여했는지 대조 구성으로 분리한다.

원격 복호·HMAC도 가능: Vault Transit API. 중앙 통제는 FHE 고유 기능이 아님

발판별 비교는 “못 얻음” 대신 경로와 조건으로 적는다

확보한 범위	pg_tde	MongoDB QE	Heracles Mode 1
DB 파일만 온라인 권한 없음	암호화 대상 파일 키 포함 여부 확인	보호 필드 암호문 메타데이터 분석	AES·FHE 암호문 메타데이터 분석
허용된 DB 조회 앱 권한 없음	허용된 조회 범위의 평문 반환	DB-only 보호 필드 직접 복호 키 없음	복호 함수 권한과 검색 결과 노출 확인
DB 호스트 장악 메모리·실행	키·평문 및 온라인 접근 관측	보호 값 직접 복호와 질의 관측·추론 구분	소켓 복호 능력과 통과하는 평문 관측
앱 장악 실제 앱 권한	DB 계정의 평문 접근 범위	앱의 키·평문 및 허용 데이터 범위	키 부재와 별개로 온라인 복호·평문 가능

앱을 통한 데이터 유출과 DB-only 암호문 접근을 같은 시나리오로 묶지 않는다.

전제: 보호 필드, 앱·DB·KMS 분리. QE 지속 관측은 공식 보장 범위와 별도로 시험

현재 확인한 구조와 아직 모르는 성질

확인

문서·코드에서 확인

FHE 검색과 원문 AES 경로는 분리
Mode 1 원문 복호 결과는 호스트 통과
검색어·적재·재색인에 평문 경로 존재
토큰화·인코딩에 따라 메타데이터 차이

미확인

실행·구현 확인 필요

HE-KMS의 실제 비반출·감사·회수
엔진 포스팅·직렬화의 접근 가능성
동등한 질의에서 QE 대비 누출 차이
침해 이후 실제 추가 복원 범위

설계 문서의 계약, 코드 경로, 실행 검증, 비교 실측은 서로 다른 증거 수준이다.

현재 기준 commit 145caef. enWord·HE-KMS 서브모듈 내부는 이번 검토에서 미확인

키 보관 서비스와 원격 복호 서비스의 차이

pg_tde · MongoDB QE

키 조회 / DEK 포장 해제

→ DB 또는 앱에서 키 사용
후속 복호는 로컬에서 가능

키 접근 횟수 ≠ 데이터 복호 횟수

Heracles Mode 1

KMS가 판정·원문 복호 수행

→ 키 대신 판정·평문 반환
배치는 여러 값을 한 번에

요청 경유 ≠ 감사·차단 검증 완료

회수 효과는 캐시, 진행 중 요청, 자격증명 재사용, 우회 경로까지 포함해 측정한다.

근거: Percona Architecture · MongoDB Keys / Key Vaults · Heracles Mode 1 §2-4

원문을 출력하지 않아도, 민감 정보는 드러날 수 있다

직접 원문 획득

복호 결과·메모리·로그에서
값을 실제로 확보

측정: 고유 행·필드·버전별
독립 확인된 평문 수

속성 추론

검색어와 매치 ID를 연결해
행의 진단·주소 등을 추정

측정: 정답률·커버리지
알려 준 값은 제외

관계·메타데이터

동일값 그룹·문자 집합·길이·
결과 수·질의 연결성

측정: 관측한 관계와
실제 값 복원의 차이

“원본 AES를 복호하지 않았다”와 “원본에 관한 정보를 얻지 못했다”는 다르다.

FHE 고유성 대신, 세 가지 검증 질문으로 시작한다

검증

H1 · 메타데이터 누출

같은 부분 일치 검색에서
구조 기반 추론이 줄어드는가?

태그 수가 적다는 사실만으로
누출이 적다고 결론 내리지 않음

계획

H2 · 질의 프라이버시

질의를 암호화한 뒤에도
반복 검색을 연결할 수 있는가?

무작위 암호문이어도 ID·접근
패턴으로 연결될 수 있음

설계

H3 · 복호 권한 분리

원문 복호 권한 없는 호스트가
필요한 검색을 수행하는가?

현재 AES 복호 경로의 분리 필요
QE 등 대안과 함께 비교

각 가설에 지지·보류·기각 조건을 둔다. FHE라는 이름을 우위의 근거로 삼지 않는다.

현재 검색어는 평문. CC-SEARCH와 원문 복호 영역 분리는 향후 설계 항목

기능 정답부터 확인하고, 침해 조건을 나눈다

먼저

C · 정상 기능

동일 질의 → 동일 정답
읽기·쓰기·삭제 후 일관성

미지원 기능은 N/A
정상 기능 실패는 보안 성공 아님

분리

A · 확보 자료 분석

A0 데이터·인덱스 파일
A1 DB·데몬 메모리 포함
A2 지속 질의·결과 관측

실제 확보 범위의 키는 포함

대조

B · 온라인 권한

B1 DB 호스트 실행
B2 앱 실행 권한
B3 회수·격리 후 추가 노출

기본 / 강화 / 통제 제거 비교

키를 인위적으로 뺀 인덱스 분석은 별도 연구 조건이다. 실제 호스트 유출과 섞지 않는다.

AI가 시도한 행동과 시스템이 막은 행동을 구분한다

Main / Planner

목표·가설·권한·예산

→

Executor

허용 도구로 병렬 실행

→

Reviewer

증거 검토·추가 확인

→

독립 검증기

정답·대상 로그로 판정

공통 기록

모델·프롬프트·도구·권한 · 벽시계 / 토큰 / 유효 호출 예산 · 증거 ID · 종료 이유

고정 스크립트 대조 + 여러 독립 AI 실행. 모델 장애·한도 소진은 통제 차단과 별도 판정.

제품 순위를 미리 그리지 않고, 같은 지표를 측정한다

관측값	정의	발표 시 주의
고유 평문 노출	독립 확인된 (행, 필드, 버전) 수	중복·이미 알려 준 값은 제외
추론 성능	정답률 + 추론한 범위	단순 빈도 추론 기준선과 비교
오프라인 추가 복원	접속 차단 후 확보 자료로 새로 얻은 값	암호문 복사량과 구별
정상 서비스 영향	정답률·성공률·지연·처리량	서비스 중단으로 만든 0 노출 제외

결과는 파일 / DB root / 앱 권한 패널로 나누고, 반복 실행의 분포와 종료 이유를 표시한다.

권한 회수는 한 시점이 아니라 세 시점으로 측정한다

회수 명령

1

정해진 시점에 조치
키·토큰·네트워크를 구분

집행 확인

2

신규 권한 사용 거절
캐시·기존 세션 확인

마지막 추가 노출

3

진행 중 배치 완료 포함
오프라인 추가 복원 별도

누적 노출량은 차단 뒤에도 감소하지 않는다. 진행 중 요청 때문에 더 늘 수 있다.

회수 “즉시” 효과는 주장하지 않는다. 적용 지연과 회수 이후 신규 노출을 실측한다.

현재 말할 수 있는 것과, 실측 후에 말할 것을 나눈다

현재

설계·코드상 확인

지정된 검색 경로는
AES 원본 복호 없이 ID 계산

Mode 1은 외부에서 키 사용
단, 평문·복호 요청 경로는 남음

실측 후

조건부 비교 주장

같은 질의·발판·예산에서
더 적은 노출 또는 추론

버전·권한·반복 결과를
함께 명시한 뒤에만 주장

제외

주장하면 안 됨

“서버가 털려도 안전”
“FHE라서 AI 공격에 강함”
“태그가 적으니 더 안전”
“AI가 실패했으니 유출 불가”

핵심은 암호 기술의 이름이 아니라, 같은 업무에서 침해 이후에도 남는 보호 경계다.

다음 단계: 비교 가능한 실험 한 묶음을 완성한다

01

구성 고정

DB 바인딩·릴리스·키 배치
시작 권한·질의 의미

02

정상 동작 확인

정답 집합·쓰기·복구
지원 / 미지원 분리

03

경계·경로 검증

엔진 메타데이터·KMS
복호·회수·오프라인 경로

04

AI 반복·주장 판정

스크립트 대조·독립 검증
지지 / 보류 / 기각

우위를 전제하지 않고 검증한다. 확인된 보호는 제품 주장으로, 미해결 경계는 개선 과제로 남긴다.

공정 비교를 위한 최소 구성 명세

명세	반드시 기록할 항목
제품·암호 구성	DB / extension / driver / crypto library 버전 · edition · 암호 파라미터 · 모드
키·권한 배치	키 종류·위치 · KMS 인증 주체 · 캐시 · 네트워크 · 공격자와 검증기 권한
업무·데이터	합성 보호 필드 · 동일 정답 · 빈도·중복·길이 분포 · 정상 부하·동시성
통제·관측	정책 집행 위치 · 우회 가능성 · 로그·메모리·백업 범위 · 회수 조치 종류

원격 키 관리라는 조건은 맞추되, 키 제공과 원격 복호의 차이는 평가 변수로 남긴다.

Heracles PostgreSQL 바인딩은 현재 문서상 유지보수 중단 MVP. 실제 Mode 1 DB 선택 필요

“부분 일치 지원”만으로는 같은 기능이 아니다

비교 조건	확인할 내용
토큰화와 정규화	값 전체 / 단어 분리 · 공백 · 대소문자 · 한글 정규화 · NULL
길이와 연산	문자열·질의 길이 · Exact / Prefix / Substring / Range · 미지원 연산
현재 Heracles	splitWords=false일 때 값 전체가 한 토큰 · 문서상 기본 45 코드포인트
현재 QE	접두·접미·부분 일치 GA 발표 확인 · 실제 선택 릴리스의 길이·설정 검증

공통 질의는 보안 비교에, 한쪽만 지원하는 질의는 기능 비교에 사용한다.

근거: Heracles overview §1.4 · MongoDB Supported Operations / 2026-09-29 GA 발표

시나리오별 확보 범위를 고정한다

ID	공격자가 확보한 범위	판정할 질문
A0	DB 데이터·인덱스·명시된 백업	키·평문·메타데이터가 실제 포함되는가?
A1	A0 + DB·데몬 메모리	서비스 단계별로 무엇이 추가되는가?
A2	정해진 기간의 DB 지속 관측	질의·ID·평문을 누적해 무엇을 추론하는가?
B1 / B2	DB 호스트 / 앱 실행 권한 각각	직접·온라인·키 재사용 중 어떤 경로가 가능한가?
B3	B1 또는 B2 도중 회수·격리	집행 이후 새 노출이 얼마나 남는가?

인위적으로 키를 제외한 구조 누출 분석은 별도 L 트랙. 실제 침해 피해와 분리한다.

에이전트의 “성공” 대신 독립 증거로 판정한다

기록

증거 기록 단위

실험 / 작업 / 대상 / 시작 권한
주장 · 실행 시각 · 도구 결과
원본 증거 ID · 정답과의 비교
새로 노출된 행·필드·버전
종료 이유와 미확인 범위

판정

종료 결과 분류

확인된 노출 / 확인된 통제 차단
관측했지만 결론 불충분
기능 미지원 / 정상 기능 실패
도구·모델 장애 / 예산 종료
각 결과를 별도로 집계

검색어·정답·fixture를 이미 알고 맞힌 것은 새 탈취가 아니다. holdout 데이터로 검증한다.

Mode 1의 현재 상태와 다음 설계를 구분한다

속성	현재 Mode 1	향후 설계·검증 과제
복호 키 위치	외부 KMS 사용 설계	서버·관리·복구 경로의 비반출 검증
원문 복호 능력	DB 호스트가 원격 복호 요청 가능	Mode 1.5: 원문 복호 영역 분리
검색어 노출	현재 SQL·데몬에서 평문	Mode 2 / CC-SEARCH: 질의 프라이버시
남는 누출	매치 ID·접근 패턴·메타데이터	암호화 후에도 남는 연결·추론 분석

소켓 ACL 강화만으로 호스트 root 경계를 넘을 수는 없다. 권한의 집행 영역을 분리해야 한다.

근거: Heracles architecture §1.3-4 · Mode 1 §2a. Mode 1.5 / Mode 2는 TBD

Heracles 근거와 검증 한계

근거	확인한 내용
spec/overview.md	평문 경로 · 토큰화·길이 · 음절표 · 포스팅 그룹 · 검색 의미
spec/architecture.md	모드별 키 배치 · 원문 복호 분리 계획 · GAP-1 · 재색인 경로
kms-integration-mode1.md	키 재료와 복호 능력 구분 · live host 한계 · batch · 원격 판정
dataplane/server.go / kms.go	handleAesDecrypt → DecryptColumn → DecryptFields → 평문 반환

enWord·HE-KMS 내부는 누락 서브모듈로 미확인. 문서 계약을 실행 보장으로 바꾸어 말하지 않는다.

검토 기준: 145caef · 문서·어댑터 코드 확인 / 공격·성능·회수 실험 미실행

공식 비교 근거 · 2026.10.19 확인

Percona pg_tde · Architecture	키 계층 · provider · 필요 시 조회와 캐시
MongoDB QE · Features / Limitations	보호 질의 값 · 클라이언트 복호 · 지속 관측 한계
MongoDB QE · Keys / Supported Operations	CMK·DEK · 질의 지원과 제약
MongoDB · 문자열 검색 GA 발표	2026-09-29 접두·접미·부분 일치 정식 지원
Vault Transit · API	중앙 키 사용·HMAC은 FHE 없이도 가능한 대조

출처와 세부 검토 의견은 발표자 노트 및 별도 HTML 피드백에 수록.

웹 문서는 변경될 수 있으므로 실험에 사용한 버전의 문서·설정을 함께 보관